

ASSESSMENT REPORT

DORA Conformity Assessment

Regulation (EU) 2022/2554

Demo Entity GmbH

AI-powered Analysis

ENTITY	Demo Entity GmbH
STANDARD	DORA
REPORT TYPE	Internal Audit & Compliance Readiness Assessment
DATE	07 June 2026
PREPARED BY	Inside the Box
STATUS	CONFIDENTIAL

Table of Contents

1 Executive Summary	
2 Subject and Scope	
3 Assessment Principles	
4 Individual Findings	
5 Complete Control Matrix	
6 Risk Landscape	
7 Recommendations and Roadmap	
9 Conclusion	
Appendix A Working Papers & Traceability	

1 Executive Summary



COMPLIANCE DISTRIBUTION

VERDICT OVERVIEW



Management Attention Index

Source: Deterministic Assessment Engine

Management Attention Index Critical (Critical 0 · High 0 · Medium 5 · Low 0)

KEY DRIVERS

% 1 mandatory control gap(s)

% Readiness 79%

Audit Readiness

Source: Deterministic Assessment Engine

Readiness (overall) Developing · 47%

Documentation Limited · 0%

0/16 controls backed by documented evidence (policy/procedure/document/audit report).

Operational Substantial · 79%

Effectiveness of implemented controls (weighted compliance score).

Governance Strong · 85%

Average of governance-related categories (4).

Evidence Limited · 25%

16/16 controls with evidence, weighted by evidence strength.

Why This Matters

This section translates the assessment results into business language for executives, board members and management teams. It frames the findings in terms of business impact, regulatory exposure, operational consequences, financial implications and strategic priorities — not just a score.

- %, Business impact — how gaps affect day-to-day operations and service delivery.
- %, Regulatory exposure — where the organisation falls short of mandatory obligations.
- %, Operational consequences — the risks that materialise if gaps remain unaddressed.
- %, Financial implications — potential cost of incidents, penalties and remediation.
- %, Strategic priorities — what management should focus on first to reduce exposure.

lightspeedconsulting.ai

2 Subject and Scope

The following section documents the intake data captured for the assessed entity. These form the basis of the rule-based assessment.

ENTITY	Demo Entity GmbH
ENTITY NAME	Acme Bank AG
TYPE OF FINANCIAL ENTITY	Credit institution
PROPORTIONALITY	Full framework
DESCRIPTION OF OPERATIONS & ICT LANDSCAPE	Regional credit institution with approx. 1,200 employees offering retail and corporate banking, payments and online banking. Core banking on a managed platform, Microsoft 365 cloud, two ICT third parties for payment processing and market data. Critical functions: payment processing, core banking ledger, online banking portal.
KEY ICT THIRD PARTIES	Cloud provider, Core banking/system, Payment processor, Market data / feeds
ESTABLISHED ROLES	Management body involved, ICT risk management function, CISO / Information security, Incident response function, ICT third-party management
KNOWN WEAKNESSES / OPEN POINTS	Register of information is incomplete for sub-outsourcing. No TLPT performed yet. Exit strategies documented only for the cloud provider, not for the core banking platform. Detection relies mainly on the MSSP without internal correlation.
ICT RESILIENCE MEASURES	ICT risk management framework, Protection & prevention controls, Detection mechanisms, Business continuity & recovery, Backup & restore, ICT incident management, Major incident reporting, Resilience testing programme, Register of information (contracts), Contractual ICT third-party clauses

3 Assessment Principles

The assessment follows an audit-safe, three-layer model: the compliance decision (pass / partial / gap) is derived strictly from the intake answers by deterministic rules. No finding is invented by the AI. Risks are derived deterministically from the gaps. The AI is used solely for the explanatory analysis layer.

How This Assessment Was Produced

- %, Assessment responses were collected through structured intake.
- %, Compliance status was determined through deterministic assessment logic.
- %, Risks were derived from the identified gaps.
- %, AI generated explanatory insights, root cause analysis, clustering, management themes and roadmap recommendations.
- %, AI did not create, modify or override findings, risks, evidence or compliance results.

lightspeedconsulting.ai

4 Individual Findings

Source: Deterministic Assessment Engine

Each requirement was assessed against the captured evidence using deterministic rules. Gaps and partial compliance are accompanied by concrete remediation recommendations.

4.1 D5-1 — Governance & management body accountability

Article: Art. 5

PASS

EVIDENCE / OBSERVATION

Evidenced: Management body involved, ICT risk management framework.

4.2 D6-1 — ICT risk management framework

Article: Art. 6

PASS

EVIDENCE / OBSERVATION

Evidenced: ICT risk management framework, ICT risk management function.

4.3 D8-1 — Identification (functions & assets)

Article: Art. 8

PARTIAL

EVIDENCE / OBSERVATION

Evidenced: ICT risk management framework, ICT risk management function.

RECOMMENDED MEASURE

Implement / evidence: Identification (functions & assets).

4.4 D9-1 — Protection & prevention

Article: Art. 9

PASS

EVIDENCE / OBSERVATION

Evidenced: Protection & prevention controls.

4.5 D10-1 — Detection of ICT incidents

Article: Art. 10

PASS

EVIDENCE / OBSERVATION

Evidenced: Detection mechanisms.

4.6 D11-1 — Business continuity & response/recovery

Article: Art. 11

PASS

EVIDENCE / OBSERVATION

Evidenced: Business continuity & recovery.

4.7 D12-1 — Backup, restoration & recovery

Article: Art. 12

PASS

EVIDENCE / OBSERVATION

Evidenced: Backup & restore.

4.8 D17-1 — ICT incident management process

Article: Art. 17

PASS

EVIDENCE / OBSERVATION

Evidenced: ICT incident management, Incident response function.

4.9 D19-1 — Reporting of major ICT incidents (4h/72h/1 month)

Article: Art. 19

PASS

EVIDENCE / OBSERVATION

Evidenced: Major incident reporting, Incident response function.

4.10 D24-1 — Digital resilience testing programme

Article: Art. 24

PASS

EVIDENCE / OBSERVATION

Evidenced: Resilience testing programme.

4.11 D26-1 — Advanced testing (TLPT)

Article: Art. 26

FAIL

EVIDENCE / OBSERVATION

No evidence provided in the intake data.

IDENTIFIED GAP

Not evidenced: Threat-led penetration testing (TLPT).

RECOMMENDED MEASURE

Implement / evidence: Threat-led penetration testing (TLPT).

4.12 D28-1 — General principles for ICT third-party risk

Article: Art. 28

PARTIAL

EVIDENCE / OBSERVATION

Evidenced: ICT third-party management, Contractual ICT third-party clauses.

RECOMMENDED MEASURE

Implement / evidence: General principles for ICT third-party risk.

4.13 D28-3 — Register of information

Article: Art. 28(3)

PASS

EVIDENCE / OBSERVATION

Evidenced: Register of information (contracts).

4.14 D28-8 — Exit strategies & concentration risk

Article: Art. 28(8)

FAIL

EVIDENCE / OBSERVATION

No evidence provided in the intake data.

IDENTIFIED GAP

Not evidenced: Exit strategies & concentration risk.

RECOMMENDED MEASURE

Implement / evidence: Exit strategies & concentration risk.

4.15 D30-1 — Key contractual provisions

Article: Art. 30

PASS

EVIDENCE / OBSERVATION

Evidenced: Contractual ICT third-party clauses.

4.16 D45-1 — Information sharing arrangements

Article: Art. 45

FAIL

EVIDENCE / OBSERVATION

No evidence provided in the intake data.

IDENTIFIED GAP

Not evidenced: Cyber threat information sharing.

RECOMMENDED MEASURE

Implement / evidence: Cyber threat information sharing.

5 Complete Control Matrix

Complete, traceable overview of all assessed requirements with verdict.

ID	Article	Topic	Verdict
D5-1	Art. 5	Governance & management body accountab	Pass
D6-1	Art. 6	ICT risk management framework	Pass
D8-1	Art. 8	Identification (functions & assets)	Partial
D9-1	Art. 9	Protection & prevention	Pass
D10-1	Art. 10	Detection of ICT incidents	Pass
D11-1	Art. 11	Business continuity & response/recover	Pass
D12-1	Art. 12	Backup, restoration & recovery	Pass
D17-1	Art. 17	ICT incident management process	Pass
D19-1	Art. 19	Reporting of major ICT incidents (4h/7	Pass
D24-1	Art. 24	Digital resilience testing programme	Pass
D26-1	Art. 26	Advanced testing (TLPT)	Gap
D28-1	Art. 28	General principles for ICT third-party	Partial
D28-3	Art. 28(3)	Register of information	Pass
D28-8	Art. 28(8)	Exit strategies & concentration risk	Gap
D30-1	Art. 30	Key contractual provisions	Pass
D45-1	Art. 45	Information sharing arrangements	Gap

Evidence Strength Overview

Source: Deterministic Assessment Engine

Informational overview of the strength of evidence supporting the assessment. It does not affect scoring or compliance status.

Very high	0 (0%)
High	0 (0%)
Medium	0 (0%)
Low	16 (100%)
No evidence	0 (0%)

6 Risk Landscape

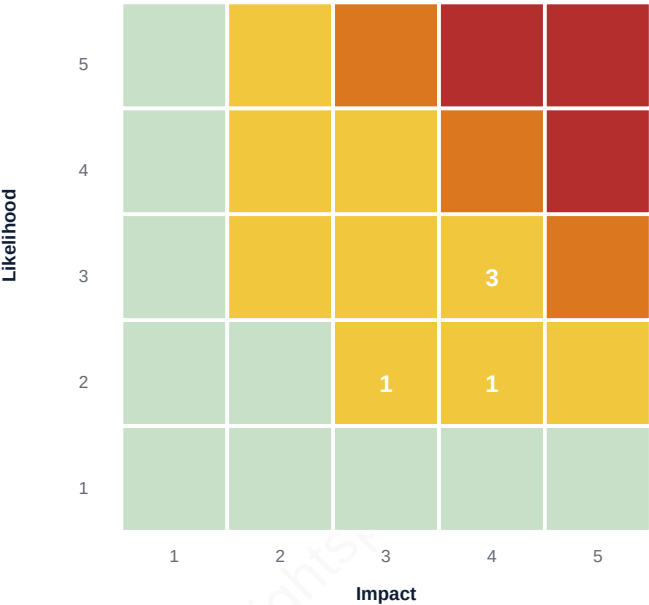
Source: Deterministic Risk Engine

The following risks were derived deterministically from the identified gaps (likelihood × impact).

RISK DISTRIBUTION



RISK HEATMAP



- R2PARTIAL: Agency in: Advanced testing (TLPT) (Impact 4 × Likelihood 3 = 12)
- R3PARTIAL: Agency in: General principles for ICT third-party risk (Impact 4 × Likelihood 3 = 12)
- R4PARTIAL: Agency in: Exit strategies & concentration risk (Impact 4 × Likelihood 3 = 12)
- R1PARTIAL: Agency in: Identification (functions & assets) (Impact 4 × Likelihood 2 = 8)
- R5PARTIAL: Agency in: Information sharing arrangements (Impact 3 × Likelihood 2 = 6)

7 Recommendations and Roadmap

Prioritised remediation plan, derived from the gaps and risks.

Implement / evidence: Threat-led penetration testing (TLPT).

Critical · 0–1 month · ICT risk management
Direct regulatory & operational exposure

Implement / evidence: Exit strategies & concentration risk.

Critical · 0–1 month · ICT third-party management
Direct regulatory & operational exposure

Implement / evidence: Cyber threat information sharing.

Critical · 0–1 month · CISO / Threat intelligence
Direct regulatory & operational exposure

Implement / evidence: Identification (functions & assets).

Medium · 3–6 months · ICT risk management
Moderate residual risk

Implement / evidence: General principles for ICT third-party risk.

Medium · 3–6 months · ICT third-party management
Moderate residual risk

Remediation Roadmap

PHASE 0-3 MONTHS

- %, Critical — Implement / evidence: Threat-led penetration testing (TLPT).
- %, Critical — Implement / evidence: Exit strategies & concentration risk.
- %, Critical — Implement / evidence: Cyber threat information sharing.

PHASE 3-6 MONTHS

- %, Medium — Implement / evidence: Identification (functions & assets).
- %, Medium — Implement / evidence: General principles for ICT third-party risk.

9 Conclusion

Demo Entity GmbH: 79% — 11 Passed, 2 Partial, 3 Gaps.

This report does not constitute a formal certification and does not replace assessment by a recognised authority. The compliance assessment is based on the information provided during intake.

REPORT METADATA

Assessment ID	DORA-MQ3SA16H
Report Title	Internal Audit & Compliance Readiness Assessment
Report Version	1.0.0
Generated	07/06/2026, 12:54:06
Assessment Engine	1.0.0
AI Insight Engine	1.0.0

Working Papers & Assessment Traceability

Source: Deterministic Assessment Engine

For every requirement this working paper records exactly why it was assessed as Pass, Partial or Gap: each assessment question with the response given, the evidence recorded (type, name, source and strength), the deterministic rule applied, the generated risk and the AI sections that referenced the requirement. No assessment result is a black box.

1. D5-1 — Governance & management body accountability

Article: Art. 5 · Rule ID: D5-1-RULE

PASS

ASSESSMENT QUESTION

Has the organization implemented and evidenced "Governance & management body accountability" as required by Art. 5?

ASSESSMENT QUESTIONS & RESPONSES

Question	Established roles
Answer	Management body involved, ICT risk management function, CISO / Information security, Incident response function, ICT third-party management
Question	ICT resilience measures
Answer	ICT risk management framework, Protection & prevention controls, Detection mechanisms, Business continuity & recovery, Backup & restore, ICT incident management, Major incident reporting, Resilience testing programme, Register of information (contracts), Contractual ICT third-party clauses
Comment	Evidenced: Management body involved, ICT risk management framework.

EVIDENCE MANAGEMENT

Evidence Type	Statement
Evidence Name	Governance & management body accountability — Statement
Evidence Source	Self-assessment (intake)
Evidence Strength	Low

EVIDENCE DESCRIPTION

Evidenced: Management body involved, ICT risk management framework.

ASSESSMENT RULE (DETERMINISTIC)

	%, IF Management body involved !' Pass
	%, IF ANY OF [ICT risk management framework] !' Partial
	%, ELSE !' Gap
Deterministic Result	Pass

RISK TRACEABILITY

No risk generated (requirement passed).

AI TRACEABILITY

Referenced by AI	No
------------------	----

AUDIT TRAIL METADATA

Assessment ID	DORA-MQ3SA16H
Assessment Version	1.0.0
Requirement ID	D5-1
Rule ID	D5-1-RULE
Assessor	Inside the Box (rule-based assessment engine)
Source System	Inside the Box — Internal Audit & Compliance Readiness Platform
Timestamp	07/06/2026, 12:54:06

2. D6-1 — ICT risk management framework

Article: Art. 6 · Rule ID: D6-1-RULE

PASS

ASSESSMENT QUESTION

Has the organization implemented and evidenced "ICT risk management framework" as required by Art. 6?

ASSESSMENT QUESTIONS & RESPONSES

Question	ICT resilience measures
Answer	ICT risk management framework, Protection & prevention controls, Detection mechanisms, Business continuity & recovery, Backup & restore, ICT incident management, Major incident reporting, Resilience testing programme, Register of information (contracts), Contractual ICT third-party clauses
Question	Established roles
Answer	Management body involved, ICT risk management function, CISO / Information security, Incident response function, ICT third-party management
Comment	Evidenced: ICT risk management framework, ICT risk management function.

EVIDENCE MANAGEMENT

Evidence Type	Statement
Evidence Name	ICT risk management framework — Statement
Evidence Source	Self-assessment (intake)
Evidence Strength	Low

EVIDENCE DESCRIPTION

Evidenced: ICT risk management framework, ICT risk management function.

ASSESSMENT RULE (DETERMINISTIC)

%,	IF	ICT risk management framework !'	Pass
%,	IF ANY OF [	ICT risk management function] !'	Partial
%,	ELSE !'	Gap	
Deterministic Result	Pass		

RISK TRACEABILITY

No risk generated (requirement passed).

AI TRACEABILITY

Referenced by AI	No
------------------	----

AUDIT TRAIL METADATA

Assessment ID	DORA-MQ3SA16H
Assessment Version	1.0.0
Requirement ID	D6-1
Rule ID	D6-1-RULE
Assessor	Inside the Box (rule-based assessment engine)
Source System	Inside the Box — Internal Audit & Compliance Readiness Platform
Timestamp	07/06/2026, 12:54:06

3. D8-1 — Identification (functions & assets)

Article: Art. 8 · Rule ID: D8-1-RULE

PARTIAL

ASSESSMENT QUESTION

Has the organization implemented and evidenced "Identification (functions & assets)" as required by Art. 8?

ASSESSMENT QUESTIONS & RESPONSES

Question	ICT resilience measures
Answer	ICT risk management framework, Protection & prevention controls, Detection mechanisms, Business continuity & recovery, Backup & restore, ICT incident management, Major incident reporting, Resilience testing programme, Register of information (contracts), Contractual ICT third-party clauses
Question	Established roles
Answer	Management body involved, ICT risk management function, CISO / Information security, Incident response function, ICT third-party management
Comment	Evidenced: ICT risk management framework, ICT risk management function.

EVIDENCE MANAGEMENT

Evidence Type	Statement
Evidence Name	Identification (functions & assets) — Statement
Evidence Source	Self-assessment (intake)
Evidence Strength	Low

EVIDENCE DESCRIPTION

Evidenced: ICT risk management framework, ICT risk management function.

ASSESSMENT RULE (DETERMINISTIC)

	<pre>%, IF ANY OF [ICT risk management framework , ICT risk management function] !' P %, ELSE !' Gap</pre>
Deterministic Result	Partial

RISK TRACEABILITY

Generated Risk	R1
Risk Formula	Likelihood 2 × Impact 4 = 8 (Medium)

AI TRACEABILITY

Referenced by AI	No
------------------	----

AUDIT TRAIL METADATA

Assessment ID	DORA-MQ3SA16H
Assessment Version	1.0.0
Requirement ID	D8-1
Rule ID	D8-1-RULE
Assessor	Inside the Box (rule-based assessment engine)
Source System	Inside the Box — Internal Audit & Compliance Readiness Platform
Timestamp	07/06/2026, 12:54:06

4. D9-1 — Protection & prevention

Article: Art. 9 · Rule ID: D9-1-RULE

PASS

ASSESSMENT QUESTION

Has the organization implemented and evidenced "Protection & prevention" as required by Art. 9?

ASSESSMENT QUESTIONS & RESPONSES

Question	ICT resilience measures
Answer	ICT risk management framework, Protection & prevention controls, Detection mechanisms, Business continuity & recovery, Backup & restore, ICT incident management, Major incident reporting, Resilience testing programme, Register of information (contracts), Contractual ICT third-party clauses
Comment	Evidenced: Protection & prevention controls.

EVIDENCE MANAGEMENT

Evidence Type	Statement
Evidence Name	Protection & prevention — Statement
Evidence Source	Self-assessment (intake)
Evidence Strength	Low

EVIDENCE DESCRIPTION

Evidenced: Protection & prevention controls.

ASSESSMENT RULE (DETERMINISTIC)

```
%, IF Protection & prevention controls !' Pass
%, IF SOME OF [ Protection & prevention controls ] !' Partial
%, ELSE !' Gap
```

Deterministic Result	Pass
----------------------	------

RISK TRACEABILITY

No risk generated (requirement passed).

AI TRACEABILITY

Referenced by AI	No
------------------	----

AUDIT TRAIL METADATA

Assessment ID	DORA-MQ3SA16H
Assessment Version	1.0.0
Requirement ID	D9-1
Rule ID	D9-1-RULE
Assessor	Inside the Box (rule-based assessment engine)

Source System	Inside the Box — Internal Audit & Compliance Readiness Platform
Timestamp	07/06/2026, 12:54:06

5. D10-1 — Detection of ICT incidents

Article: Art. 10 · Rule ID: D10-1-RULE

PASS

ASSESSMENT QUESTION

Has the organization implemented and evidenced "Detection of ICT incidents" as required by Art. 10?

ASSESSMENT QUESTIONS & RESPONSES

Question	ICT resilience measures
Answer	ICT risk management framework, Protection & prevention controls, Detection mechanisms, Business continuity & recovery, Backup & restore, ICT incident management, Major incident reporting, Resilience testing programme, Register of information (contracts), Contractual ICT third-party clauses
Comment	Evidenced: Detection mechanisms.

Evidence Type	Statement
Evidence Name	Detection of ICT incidents — Statement
Evidence Source	Self-assessment (intake)
Evidence Strength	Low

EVIDENCE DESCRIPTION

Evidenced: Detection mechanisms.

ASSESSMENT RULE (DETERMINISTIC)

```
%, IF Detection mechanisms !' Pass
%, IF SOME OF [ Detection mechanisms ] !' Partial
%, ELSE !' Gap
```

Deterministic Result	Pass
----------------------	------

RISK TRACEABILITY

No risk generated (requirement passed).

AI TRACEABILITY

Referenced by AI	No
------------------	----

AUDIT TRAIL METADATA	
Assessment ID	DORA-MQ3SA16H
Assessment Version	1.0.0

Requirement ID	D10-1
Rule ID	D10-1-RULE
Assessor	Inside the Box (rule-based assessment engine)
Source System	Inside the Box — Internal Audit & Compliance Readiness Platform
Timestamp	07/06/2026, 12:54:06

6. D11-1 — Business continuity & response/recovery

Article: Art. 11 · Rule ID: D11-1-RULE

PASS

ASSESSMENT QUESTION

Has the organization implemented and evidenced "Business continuity & response/recovery" as required by Art. 11?

ASSESSMENT QUESTIONS & RESPONSES

Question	ICT resilience measures
Answer	ICT risk management framework, Protection & prevention controls, Detection mechanisms, Business continuity & recovery, Backup & restore, ICT incident management, Major incident reporting, Resilience testing programme, Register of information (contracts), Contractual ICT third-party clauses
Comment	Evidenced: Business continuity & recovery.

EVIDENCE MANAGEMENT

Evidence Type	Statement
Evidence Name	Business continuity & response/recovery — Statement
Evidence Source	Self-assessment (intake)
Evidence Strength	Low

EVIDENCE DESCRIPTION

Evidenced: Business continuity & recovery.

ASSESSMENT RULE (DETERMINISTIC)

%,	IF Business continuity & recovery !' Pass
%,	IF SOME OF [Business continuity & recovery] !' Partial
%,	ELSE !' Gap
Deterministic Result	Pass

RISK TRACEABILITY

No risk generated (requirement passed).

AI TRACEABILITY

Referenced by AI	No
------------------	----

AUDIT TRAIL METADATA

Assessment ID	DORA-MQ3SA16H
Assessment Version	1.0.0
Requirement ID	D11-1
Rule ID	D11-1-RULE
Assessor	Inside the Box (rule-based assessment engine)
Source System	Inside the Box — Internal Audit & Compliance Readiness Platform
Timestamp	07/06/2026, 12:54:06

7. D12-1 — Backup, restoration & recovery

Article: Art. 12 · Rule ID: D12-1-RULE

PASS

ASSESSMENT QUESTION

Has the organization implemented and evidenced "Backup, restoration & recovery" as required by Art. 12?

ASSESSMENT QUESTIONS & RESPONSES

Question	ICT resilience measures
Answer	ICT risk management framework, Protection & prevention controls, Detection mechanisms, Business continuity & recovery, Backup & restore, ICT incident management, Major incident reporting, Resilience testing programme, Register of information (contracts), Contractual ICT third-party clauses
Comment	Evidenced: Backup & restore.

EVIDENCE MANAGEMENT

Evidence Type	Statement
Evidence Name	Backup, restoration & recovery — Statement
Evidence Source	Self-assessment (intake)
Evidence Strength	Low

EVIDENCE DESCRIPTION

Evidenced: Backup & restore.

ASSESSMENT RULE (DETERMINISTIC)

%,	IF Backup & restore !' Pass
%,	IF SOME OF [Backup & restore] !' Partial
%,	ELSE !' Gap
Deterministic Result	Pass

RISK TRACEABILITY

No risk generated (requirement passed).

AI TRACEABILITY

Referenced by AI No

AUDIT TRAIL METADATA

Assessment ID DORA-MQ3SA16H

Assessment Version 1.0.0

Requirement ID D12-1

Rule ID D12-1-RULE

Assessor Inside the Box (rule-based assessment engine)

Source System Inside the Box — Internal Audit & Compliance Readiness Platform

Timestamp 07/06/2026, 12:54:06

8. D17-1 — ICT incident management process

Article: Art. 17 · Rule ID: D17-1-RULE

PASS

ASSESSMENT QUESTION

Has the organization implemented and evidenced "ICT incident management process" as required by Art. 17?

ASSESSMENT QUESTIONS & RESPONSES

Question ICT resilience measures

Answer ICT risk management framework, Protection & prevention controls, Detection mechanisms, Business continuity & recovery, Backup & restore, ICT incident management, Major incident reporting, Resilience testing programme, Register of information (contracts), Contractual ICT third-party clauses

Question Established roles

Answer Management body involved, ICT risk management function, CISO / Information security, Incident response function, ICT third-party management

Comment Evidenced: ICT incident management, Incident response function.

EVIDENCE MANAGEMENT

Evidence Type Statement

Evidence Name ICT incident management process — Statement

Evidence Source Self-assessment (intake)

Evidence Strength Low

EVIDENCE DESCRIPTION

Evidenced: ICT incident management, Incident response function.

ASSESSMENT RULE (DETERMINISTIC)

```
%, IF ICT incident management !' Pass
%, IF ANY OF [ Incident response function ] !' Partial
%, ELSE !' Gap
```

Deterministic Result Pass

RISK TRACEABILITY

No risk generated (requirement passed).

AI TRACEABILITY

Referenced by AI No

AUDIT TRAIL METADATA

Assessment ID DORA-MQ3SA16H

Assessment Version 1.0.0

Requirement ID D17-1

Rule ID D17-1-RULE

Assessor Inside the Box (rule-based assessment engine)

Source System Inside the Box — Internal Audit & Compliance Readiness Platform

Timestamp 07/06/2026, 12:54:06

9. D19-1 — Reporting of major ICT incidents (4h/72h/1 month)

Article: Art. 19 · Rule ID: D19-1-RULE

PASS

ASSESSMENT QUESTION

Has the organization implemented and evidenced "Reporting of major ICT incidents (4h/72h/1 month)" as required by Art. 19?

ASSESSMENT QUESTIONS & RESPONSES

Question ICT resilience measures

Answer ICT risk management framework, Protection & prevention controls, Detection mechanisms, Business continuity & recovery, Backup & restore, ICT incident management, Major incident reporting, Resilience testing programme, Register of information (contracts), Contractual ICT third-party clauses

Question Established roles

Answer Management body involved, ICT risk management function, CISO / Information security, Incident response function, ICT third-party management

Comment Evidenced: Major incident reporting, Incident response function.

EVIDENCE MANAGEMENT

Evidence Type	Statement
Evidence Name	Reporting of major ICT incidents (4h/72h/1 month) — Statement
Evidence Source	Self-assessment (intake)
Evidence Strength	Low

EVIDENCE DESCRIPTION

Evidenced: Major incident reporting, Incident response function.

ASSESSMENT RULE (DETERMINISTIC)

%,	IF	Major incident reporting	!	'	Pass
%,	IF	ANY OF [	Incident response function	]	!' Partial
%,	ELSE	!	'	Gap	
Deterministic Result	Pass				

RISK TRACEABILITY

No risk generated (requirement passed).

AI TRACEABILITY

Referenced by AI	No
------------------	----

AUDIT TRAIL METADATA

Assessment ID	DORA-MQ3SA16H
Assessment Version	1.0.0
Requirement ID	D19-1
Rule ID	D19-1-RULE
Assessor	Inside the Box (rule-based assessment engine)
Source System	Inside the Box — Internal Audit & Compliance Readiness Platform
Timestamp	07/06/2026, 12:54:06

10. D24-1 — Digital resilience testing programme

Article: Art. 24 · Rule ID: D24-1-RULE

PASS

ASSESSMENT QUESTION

Has the organization implemented and evidenced "Digital resilience testing programme" as required by Art. 24?

ASSESSMENT QUESTIONS & RESPONSES

Question	ICT resilience measures
Answer	ICT risk management framework, Protection & prevention controls, Detection mechanisms, Business continuity & recovery, Backup & restore, ICT incident management, Major incident reporting, Resilience testing programme, Register of information (contracts), Contractual ICT third-party clauses
Comment	Evidenced: Resilience testing programme.

EVIDENCE MANAGEMENT

Evidence Type	Statement
Evidence Name	Digital resilience testing programme — Statement
Evidence Source	Self-assessment (intake)
Evidence Strength	Low

EVIDENCE DESCRIPTION

Evidenced: Resilience testing programme.

ASSESSMENT RULE (DETERMINISTIC)

```
%, IF Resilience testing programme !' Pass
%, IF SOME OF [ Resilience testing programme ] !' Partial
%, ELSE !' Gap
```

Deterministic Result	Pass
----------------------	------

RISK TRACEABILITY

No risk generated (requirement passed).

AI TRACEABILITY

Referenced by AI	No
------------------	----

AUDIT TRAIL METADATA

Assessment ID	DORA-MQ3SA16H
Assessment Version	1.0.0
Requirement ID	D24-1
Rule ID	D24-1-RULE
Assessor	Inside the Box (rule-based assessment engine)

Source System	Inside the Box — Internal Audit & Compliance Readiness Platform
Timestamp	07/06/2026, 12:54:06

11. D26-1 — Advanced testing (TLPT)

Article: Art. 26 · Rule ID: D26-1-RULE

FAIL

ASSESSMENT QUESTION

Has the organization implemented and evidenced "Advanced testing (TLPT)" as required by Art. 26?

ASSESSMENT QUESTIONS & RESPONSES

Question	ICT resilience measures
Answer	ICT risk management framework, Protection & prevention controls, Detection mechanisms, Business continuity & recovery, Backup & restore, ICT incident management, Major incident reporting, Resilience testing programme, Register of information (contracts), Contractual ICT third-party clauses
Comment	No evidence provided in the intake data.

EVIDENCE MANAGEMENT

Evidence Type	Statement
Evidence Name	Advanced testing (TLPT) — Statement
Evidence Source	Self-assessment (intake)
Evidence Strength	Low

EVIDENCE DESCRIPTION

No evidence provided in the intake data.

ASSESSMENT RULE (DETERMINISTIC)

%	IF Threat-led penetration testing (TLPT) !' Pass
%	IF SOME OF [Threat-led penetration testing (TLPT)] !' Partial
%	ELSE !' Gap
Deterministic Result	Gap

RISK TRACEABILITY

Generated Risk	R2
Risk Formula	Likelihood 3 × Impact 4 = 12 (Medium)

AI TRACEABILITY

Referenced by AI	No
------------------	----

AUDIT TRAIL METADATA

Assessment ID	DORA-MQ3SA16H
---------------	---------------

Assessment Version	1.0.0
Requirement ID	D26-1
Rule ID	D26-1-RULE
Assessor	Inside the Box (rule-based assessment engine)
Source System	Inside the Box — Internal Audit & Compliance Readiness Platform
Timestamp	07/06/2026, 12:54:06

12. D28-1 — General principles for ICT third-party risk

Article: Art. 28 · Rule ID: D28-1-RULE

PARTIAL

ASSESSMENT QUESTION

Has the organization implemented and evidenced "General principles for ICT third-party risk" as required by Art. 28?

ASSESSMENT QUESTIONS & RESPONSES

Question	Established roles
Answer	Management body involved, ICT risk management function, CISO / Information security, Incident response function, ICT third-party management
Question	ICT resilience measures
Answer	ICT risk management framework, Protection & prevention controls, Detection mechanisms, Business continuity & recovery, Backup & restore, ICT incident management, Major incident reporting, Resilience testing programme, Register of information (contracts), Contractual ICT third-party clauses
Comment	Evidenced: ICT third-party management, Contractual ICT third-party clauses.

EVIDENCE MANAGEMENT

Evidence Type	Statement
Evidence Name	General principles for ICT third-party risk — Statement
Evidence Source	Self-assessment (intake)
Evidence Strength	Low

EVIDENCE DESCRIPTION

Evidenced: ICT third-party management, Contractual ICT third-party clauses.

ASSESSMENT RULE (DETERMINISTIC)

% IF ANY OF [ICT third-party management , Contractual ICT third-party clauses] !'

% ELSE !' Gap

Deterministic ResultPartial

RISK TRACEABILITY

Generated Risk	R3
Risk Formula	Likelihood 3 × Impact 4 = 12 (Medium)

AI TRACEABILITY

Referenced by AI	No
------------------	----

AUDIT TRAIL METADATA

Assessment ID	DORA-MQ3SA16H
Assessment Version	1.0.0
Requirement ID	D28-1
Rule ID	D28-1-RULE
Assessor	Inside the Box (rule-based assessment engine)
Source System	Inside the Box — Internal Audit & Compliance Readiness Platform
Timestamp	07/06/2026, 12:54:06

13. D28-3 — Register of information

Article: Art. 28(3) · Rule ID: D28-3-RULE

PASS

ASSESSMENT QUESTION

Has the organization implemented and evidenced "Register of information" as required by Art. 28(3)?

ASSESSMENT QUESTIONS & RESPONSES

Question	ICT resilience measures
Answer	ICT risk management framework, Protection & prevention controls, Detection mechanisms, Business continuity & recovery, Backup & restore, ICT incident management, Major incident reporting, Resilience testing programme, Register of information (contracts), Contractual ICT third-party clauses
Comment	Evidenced: Register of information (contracts).

EVIDENCE MANAGEMENT

Evidence Type	Statement
Evidence Name	Register of information — Statement
Evidence Source	Self-assessment (intake)
Evidence Strength	Low

EVIDENCE DESCRIPTION

Evidenced: Register of information (contracts).

ASSESSMENT RULE (DETERMINISTIC)

%,	IF	Register of information (contracts) !'	Pass
%,	IF SOME OF [	Register of information (contracts)] !'	Partial
%,	ELSE !'	Gap	
Deterministic Result	Pass		

RISK TRACEABILITY

No risk generated (requirement passed).

AI TRACEABILITY

Referenced by AI	No
------------------	----

AUDIT TRAIL METADATA

Assessment ID	DORA-MQ3SA16H
Assessment Version	1.0.0
Requirement ID	D28-3
Rule ID	D28-3-RULE
Assessor	Inside the Box (rule-based assessment engine)
Source System	Inside the Box — Internal Audit & Compliance Readiness Platform
Timestamp	07/06/2026, 12:54:06

14. D28-8 — Exit strategies & concentration risk

Article: Art. 28(8) · Rule ID: D28-8-RULE

FAIL

ASSESSMENT QUESTION

Has the organization implemented and evidenced "Exit strategies & concentration risk" as required by Art. 28(8)?

ASSESSMENT QUESTIONS & RESPONSES

Question	ICT resilience measures
Answer	ICT risk management framework, Protection & prevention controls, Detection mechanisms, Business continuity & recovery, Backup & restore, ICT incident management, Major incident reporting, Resilience testing programme, Register of information (contracts), Contractual ICT third-party clauses
Comment	No evidence provided in the intake data.

EVIDENCE MANAGEMENT

Evidence Type	Statement
Evidence Name	Exit strategies & concentration risk — Statement
Evidence Source	Self-assessment (intake)

Evidence Strength	Low
EVIDENCE DESCRIPTION	
No evidence provided in the intake data.	
ASSESSMENT RULE (DETERMINISTIC)	
% IF Exit strategies & concentration risk !' Pass	
% IF SOME OF [Exit strategies & concentration risk] !' Partial	
% ELSE !' Gap	
Deterministic Result	Gap
RISK TRACEABILITY	
Generated Risk	R4
Risk Formula	Likelihood 3 × Impact 4 = 12 (Medium)
AI TRACEABILITY	
Referenced by AI	No
AUDIT TRAIL METADATA	
Assessment ID	DORA-MQ3SA16H
Assessment Version	1.0.0
Requirement ID	D28-8
Rule ID	D28-8-RULE
Assessor	Inside the Box (rule-based assessment engine)
Source System	Inside the Box — Internal Audit & Compliance Readiness Platform
Timestamp	07/06/2026, 12:54:06

15. D30-1 — Key contractual provisions

Article: Art. 30 · Rule ID: D30-1-RULE

PASS	
ASSESSMENT QUESTION	
Has the organization implemented and evidenced "Key contractual provisions" as required by Art. 30?	
ASSESSMENT QUESTIONS & RESPONSES	
Question	ICT resilience measures
Answer	ICT risk management framework, Protection & prevention controls, Detection mechanisms, Business continuity & recovery, Backup & restore, ICT incident management, Major incident reporting, Resilience testing programme, Register of information (contracts), Contractual ICT third-party clauses
Comment	Evidenced: Contractual ICT third-party clauses.

EVIDENCE MANAGEMENT

Evidence Type	Statement
Evidence Name	Key contractual provisions — Statement
Evidence Source	Self-assessment (intake)
Evidence Strength	Low

EVIDENCE DESCRIPTION

Evidenced: Contractual ICT third-party clauses.

ASSESSMENT RULE (DETERMINISTIC)

%,	IF	Contractual ICT third-party clauses !'	Pass
%,	IF SOME OF [	Contractual ICT third-party clauses] !'	Partial
%,	ELSE !'	Gap	
Deterministic Result	Pass		

RISK TRACEABILITY

No risk generated (requirement passed).

AI TRACEABILITY

Referenced by AI	No
------------------	----

AUDIT TRAIL METADATA

Assessment ID	DORA-MQ3SA16H
Assessment Version	1.0.0
Requirement ID	D30-1
Rule ID	D30-1-RULE
Assessor	Inside the Box (rule-based assessment engine)
Source System	Inside the Box — Internal Audit & Compliance Readiness Platform
Timestamp	07/06/2026, 12:54:06

16. D45-1 — Information sharing arrangements

Article: Art. 45 · Rule ID: D45-1-RULE

FAIL

ASSESSMENT QUESTION

Has the organization implemented and evidenced "Information sharing arrangements" as required by Art. 45?

ASSESSMENT QUESTIONS & RESPONSES

Question	ICT resilience measures
Answer	ICT risk management framework, Protection & prevention controls, Detection mechanisms, Business continuity & recovery, Backup & restore, ICT incident management, Major incident reporting, Resilience testing programme, Register of information (contracts), Contractual ICT third-party clauses
Comment	No evidence provided in the intake data.

EVIDENCE MANAGEMENT

Evidence Type	Statement
Evidence Name	Information sharing arrangements — Statement
Evidence Source	Self-assessment (intake)
Evidence Strength	Low

EVIDENCE DESCRIPTION

No evidence provided in the intake data.

ASSESSMENT RULE (DETERMINISTIC)

%,	IF	Cyber threat information sharing	!	Pass
%,	IF	SOME OF [Cyber threat information sharing]	!	Partial
%,	ELSE	!	Gap	
Deterministic Result	Gap			

RISK TRACEABILITY

Generated Risk	R5
Risk Formula	Likelihood 2 × Impact 3 = 6 (Medium)

AI TRACEABILITY

Referenced by AI	No
------------------	----

AUDIT TRAIL METADATA

Assessment ID	DORA-MQ3SA16H
Assessment Version	1.0.0
Requirement ID	D45-1
Rule ID	D45-1-RULE

Assessor Inside the Box (rule-based assessment engine)

Source System Inside the Box — Internal Audit & Compliance Readiness Platform

Timestamp 07/06/2026, 12:54:06

Evidence Register (Appendix)

Source: Deterministic Assessment Engine

Every evidence item mapped to its requirement, type, strength and assessment contribution.

ID	Req.	Type	Strength	Result
E-001	D5-1	Statement	Low	Pass
E-002	D6-1	Statement	Low	Pass
E-003	D8-1	Statement	Low	Partial
E-004	D9-1	Statement	Low	Pass
E-005	D10-1	Statement	Low	Pass
E-006	D11-1	Statement	Low	Pass
E-007	D12-1	Statement	Low	Pass
E-008	D17-1	Statement	Low	Pass
E-009	D19-1	Statement	Low	Pass
E-010	D24-1	Statement	Low	Pass
E-011	D26-1	Statement	Low	Gap
E-012	D28-1	Statement	Low	Partial
E-013	D28-3	Statement	Low	Pass
E-014	D28-8	Statement	Low	Gap
E-015	D30-1	Statement	Low	Pass
E-016	D45-1	Statement	Low	Gap

E-001 — D5-1

Requirement	Governance & management body accountability
Type	Statement
Strength	Low
Used For	Governance & management body accountability
Result Contribution	Pass

DESCRIPTION

Evidenced: Management body involved, ICT risk management framework.

E-002 — D6-1

Requirement	ICT risk management framework
Type	Statement
Strength	Low
Used For	ICT risk management framework
Result Contribution	Pass

DESCRIPTION

Evidenced: ICT risk management framework, ICT risk management function.

E-003 — D8-1

Requirement Identification (functions & assets)

Type Statement

Strength Low

Used For Identification (functions & assets)

Result Contribution Partial

DESCRIPTION

Evidenced: ICT risk management framework, ICT risk management function.

E-004 — D9-1

Requirement Protection & prevention

Type Statement

Strength Low

Used For Protection & prevention

Result Contribution Pass

DESCRIPTION

Evidenced: Protection & prevention controls.

E-005 — D10-1

Requirement Detection of ICT incidents

Type Statement

Strength Low

Used For Detection of ICT incidents

Result Contribution Pass

DESCRIPTION

Evidenced: Detection mechanisms.

E-006 — D11-1

Requirement Business continuity & response/recovery

Type Statement

Strength Low

Used For Business continuity & response/recovery

Result Contribution Pass

DESCRIPTION

Evidenced: Business continuity & recovery.

E-007 — D12-1

Requirement Backup, restoration & recovery

Type Statement

Strength Low

Used For Backup, restoration & recovery

Result Contribution Pass

DESCRIPTION

Evidenced: Backup & restore.

E-008 — D17-1

Requirement ICT incident management process

Type Statement

Strength Low

Used For ICT incident management process

Result Contribution Pass

DESCRIPTION

Evidenced: ICT incident management, Incident response function.

E-009 — D19-1

Requirement Reporting of major ICT incidents (4h/72h/1 month)

Type Statement

Strength Low

Used For Reporting of major ICT incidents (4h/72h/1 month)

Result Contribution Pass

DESCRIPTION

Evidenced: Major incident reporting, Incident response function.

E-010 — D24-1

Requirement Digital resilience testing programme

Type Statement

Strength Low

Used For Digital resilience testing programme

Result Contribution Pass

DESCRIPTION

Evidenced: Resilience testing programme.

E-011 — D26-1

Requirement Advanced testing (TLPT)

Type Statement

Strength Low

Used For Advanced testing (TLPT)

Result Contribution Gap

DESCRIPTION

No evidence provided in the intake data.

E-012 — D28-1

Requirement General principles for ICT third-party risk

Type Statement

Strength Low

Used For General principles for ICT third-party risk

Result Contribution Partial

DESCRIPTION

Evidenced: ICT third-party management, Contractual ICT third-party clauses.

E-013 — D28-3

Requirement Register of information

Type Statement

Strength Low

Used For Register of information

Result Contribution Pass

DESCRIPTION

Evidenced: Register of information (contracts).

E-014 — D28-8

Requirement Exit strategies & concentration risk

Type Statement

Strength Low

Used For Exit strategies & concentration risk

Result Contribution Gap

DESCRIPTION

No evidence provided in the intake data.

E-015 — D30-1

Requirement Key contractual provisions

Type Statement

Strength Low

Used For Key contractual provisions

Result Contribution Pass

DESCRIPTION

Evidenced: Contractual ICT third-party clauses.

E-016 — D45-1

Requirement Information sharing arrangements

Type Statement

Strength	Low
Used For	Information sharing arrangements
Result Contribution	Gap

DESCRIPTION

No evidence provided in the intake data.

lightspeedconsulting.ai